HAICHAIN

HAICHAIN ИНСТИТУЦИОНАЛЬНЫЙ АУДИТ БЕЗОПАСНОСТИ И ОЦЕНКА РИСКОВ

ОТЧЕТ О РИСКАХ ИНСТИТУЦИОНАЛЬНОГО УРОВНЯ V1.1 • СТАНДАРТ КРИПТОГРАФИЧЕСКОЙ ЗАЩИТЫ

HAICHAIN: Отчет об Институциональном Дью-Дилидженсе Рисков

Математические Доказательства, Моделирование Угроз и Матрица Верификации Red-Team для Инвесторов Tier-1

ЦЕЛЕВАЯ АУДИТОРИЯ

Фонды Tier-1 и Аудиторские Компании

КРИПТОГРАФИЧЕСКАЯ ЗАЩИТА

Аппаратный Passkey • 9 Инвариантов

ЯДРО ПРОТОКОЛА

HAICHAIN v1.1 • CapLeaf 223 Байта

ОТЧЕТ ОБ ИНСТИТУЦИОНАЛЬНОМ ДЬЮ-ДИЛИДЖЕНСЕ РИСКОВ HAICHAIN

Математические Доказательства, Моделирование Угроз и Матрица Верификации Red-Team

Целевая аудитория: Венчурные фонды Tier-1 (a16z crypto, Paradigm, Sequoia), институциональные кастодианы и ведущие аудиторские компании (OtterSec, Neodyme, Kudelski Security)
Версия протокола: HAICHAIN Kernel v1.1 / CapLeaf v1 (Сетевая схема 223 байта)
Технические стандарты: Anchor Framework (Solana L1) + Sui Move (`AgentCap`) + Tron Rail Intent Solver

1. ИСПОЛНИТЕЛЬНОЕ РЕЗЮМЕ И ПАРАДИГМА БЕЗОПАСНОСТИ

Автономные ИИ-агенты, осуществляющие микроплатежи, создают принципиально иные векторы атак по сравнению с традиционными DeFi: 1. **Нулевая задержка без участия человека:** ИИ-агент при выполнении вызовов инструментов может быть скомпрометирован посредством непрямой инъекции промпта (Indirect Prompt Injection) и выпустить тысячи несанкционированных платежных ваучеров за считанные секунды. 2. **Уязвимость утечки закрытых ключей:** Работа экземпляров агентов на распределенных узлах (Cloudflare Workers, локальные MCP, бессерверные функции) увеличивает риск компрометации закрытых ключей. 3. **Размножение мошеннических мерчантов (Sybil):** В открытой сети M2M злоумышленники могут регистрировать неограниченное количество временных доменов для обхода ограничений частоты запросов.

Для полного решения этой задачи без ущерба для субмиллисекундной скорости **HAICHAIN полностью разделяет исполнение платежей и хранение капитала**: - **Высший суверенный контроль:** Аппаратный биометрический ключ WebAuthn FIDO2 Passkey (P-256) сохраняет 100% суверенное владение пулом средств. - **Изоляция прав субагентов:** Временные пары ключей Ed25519 строго изолированы в межпроцессном механизме политик (Policy Engine) без доступа к мнемонической фразе кошелька. - **Ончейн Merkle-якорь:** Схема дескриптора полномочий (223 байта) жестко обеспечивает выполнение 9 математических инвариантов ($I_1 \dots I_9$).

2. ФОРМАЛЬНАЯ МОДЕЛЬ УГРОЗ И ОГРАНИЧЕНИЕ УБЫТКОВ

2.1. Классификация поверхности атак

Класс угрозы	Сценарий	Традиционный риск Web3	Предельные потери в HAICHAIN
T_1 (Инъекция промпта)	LLM принуждают заплатить неавторизованному мерчанту	Полное опустошение кошелька (`100,000+`)	$E_{\text{theft}} = 0$ (Блокируется белым списком корня Merkle)
T_2 (Сговор мерчанта)	Легитимный мерчант пытается дважды заявить ваучер	Двойное списание с баланса	$E_{theft} = 0$ (Anchor гарантирует $P_i \le \min(C_i, R_i)$)
T_3 (Атака через новый API)	Субагент пытается истощить лимит на непроверенном API	Постепенное истощение пула	$E_{theft} \le M_{tpl}$ (Ограничено общим бюджетом шаблона)
T_4 (Полный захват агента)	Утечка ключа + сговор с мерчантом из белого списка	Мгновенный вывод всех средств	$E_{theft}(\tau) \le \min(B, K, W_p \cdot n(\tau, \omega_p))$

2.2. Теорема 6.1: Верхняя граница потерь в худшем сценарии (τ_4)

Пусть τ — общее время отклика протокола от момента первой неавторизованной транзакции до подтверждения транзакции экстренной заморозки (Panic Freeze) в блокчейне:

$$\tau = t_{detect} + t_{owner} + t_{land}$$

где $t_{detect} \le 5.0c$, $t_{owner} \le 2.0c$, $t_{land} \le 5.0c$.

Максимальный совокупный ущерб $E_{theft}(\tau)$ математически строго ограничен:

$$E_{theft}(\tau) \le \min(B,\; K,\; W_p \cdot n(\tau,\, \omega_p),\; \sum_{i:\, m_i \in \mathcal{A}} E_i(\tau))$$

Вывод: Для институционального пула с балансом `10,000 USDT`, лимитом на лист `50 USDT` и ограничением скорости `10 USDT / час`, злоумышленник, получивший ключ агента, **не сможет похитить более** `10 USDT` до срабатывания заморозки, сохраняя `9,990 USDT` **(99.9%)** средств фонда.

---

3. МАТРИЦА АППАРАТНОГО УКРЕПЛЕНИЯ RED-TEAM

№	Вектор Атаки	Механизм Уязвимости	Аппаратный Ончейн Инвариант
1	Двойное Списание Эскроу	Отправка нескольких накопительных ваучеров на сумму выше лимита	Монотонный Необратимый Расчет: $P_i \le \min(C_i, R_i)$
2	Перехват Аккаунта ATA	Подмена адреса получателя токенов на посторонний адрес	Жесткая Каноническая Привязка Валидация ассоциированного ATA
3	Обход Panic Freeze	Попытка закрыть канал после активации экстренной заморозки	Мгновенная Изоляция Эпохи (I_6 Все старые ваучеры недействител
4	Вампирский Слив Аренды	Хищение Lamports аренды при закрытии канала	Возврат Аренды Создателю Автоматический возврат в пул
5	Sybil-Атака Микро-Циклов	Создание 1 000 дочерних листьев для распыления баланса	Сжигание Лимита Шаблона Списание из родительского пула

---

4. ОТЧЕТ ОБ АУДИТЕ 9 МАТЕМАТИЧЕСКИХ ИНВАРИАНТОВ ($I_1 \dots I_9$)

Все инструкции в `programs/haichain-core/src/lib.rs` строго соблюдают инварианты: 1. I_1 **(Сохранение Капитала):** Баланс ATA + Эскроу + Выплачено + Возвраты ≡ Чистые Депозиты. 2. I_2 **(Безопасность Получателя):** Аккаунт ATA строго равен ассоциированному токен-аккаунту мерчанта. 3. I_3 **(Потолок Бюджета):** Фактические расходы строго меньше или равны выделенному бюджету. 4. I_4 **(Автономный Скоростной Лимит):** Расход в рамках скользящего окна строго ограничен. 5. I_5 **(Монотонное Сужение Прав PDA):** Дочерние инстансы не могут расширять права родителя. 6. I_6 **(Изоляция Эпохи Panic Freeze):** Немедленная аннуляция всех обращающихся ваучеров. 7. I_7 **(Истечение Сессии Heartbeat):** Запрет новых резервов после окончания таймаута. 8. I_8 **(Однократный Расчет):** Исключение любых повторных списаний. 9. I_9 **(Изоляция Аккаунтов Sybil):** Каждая способность привязана ровно к одному ончейн PDA.

5. ТОКЕНОМИКА И РЕГУЛЯТОРНОЕ СООТВЕТСТВИЕ

- **100% Утилитарный стандарт (Иммунитет к Howey и MiCA):** Отсутствие пассивного стейкинга и дивидендов.
- **50% Buyback & Burn:** 50% сетевых сборов направляются на открытый выкуп $HAISI и постоянное сжигание.
- **50% Резервный фонд (CHGB):** Гарантия ликвидности и соблюдения SLA поставщиков.

6. ЗАКЛЮЧЕНИЕ И ДОСТУП К DATA ROOM

HAICHAIN v1.1 представляет собой первый в мире математически доказанный и аппаратно изолированный платежный уровень для автономных ИИ-агентов.